

SGSI-UNCP

Procedimiento de Gestión de Seguridad con Proveedores

Documento Base del Sistema de Gestión
de Seguridad de la Información

Universidad Nacional del Centro del Perú

Índice

- 1 Procedimiento de Gestión de Seguridad con Proveedores
 - 1.1 Objetivo
 - 1.2 Alcance
 - 1.3 Ciclo de Vida de la Gestión del Proveedor
 - 1.4 Requisitos de Seguridad por Tipo de Servicio
 - 1.5 Matriz de Proveedores Críticos (Registro)
 - 1.6 Documentos Relacionados

1. Procedimiento de Gestión de Seguridad con Proveedores

Organización: Universidad Nacional del Centro del Perú (UNCP) **Aprobado por:** Oficial de Seguridad y Confianza Digital **Norma:** ISO/IEC 27001:2022 (Controles A.5.19 – A.5.23) **Alineamiento:** POL-SGSI-04 (Política de Seguridad con Proveedores), D-SGSI-04 (Metodología de Riesgos)

1.1. Objetivo

Establecer el proceso operativo para la evaluación, contratación, monitoreo y cese de proveedores con acceso a información, sistemas o instalaciones de la UNCP, asegurando que los riesgos de seguridad sean gestionados durante todo el ciclo de vida de la relación contractual.

1.2. Alcance

Este procedimiento aplica a todos los proveedores clasificados como **Críticos** y **Alto** según la POL-SGSI-04, que tengan acceso a datos institucionales, infraestructura tecnológica o instalaciones físicas de la UNCP.

1.3. Ciclo de Vida de la Gestión del Proveedor

1.3.1. 3.1 Fase Precontractual

Paso	Actividad	Responsable	Documento Generado
1.1	Identificar la necesidad de contratación y el tipo de servicio	Área usuaria	Requerimiento técnico
1.2	Clasificar al proveedor según nivel de riesgo (Crítico/Alto/Medio/Bajo)	Oficial de Seguridad + OTI	Clasificación según POL-SGSI-04
1.3	Elaborar los requisitos de seguridad obligatorios para incluir en las bases	Oficial de Seguridad	Anexo de requisitos de seguridad
1.4	Incluir en el contrato las cláusulas de seguridad definidas en la POL-SGSI-04	Asesoría Jurídica + Abastecimiento	Contrato con cláusulas SGSI
1.5	Evaluar la madurez de seguridad del postor adjudicado (certificaciones, incidentes previos)	OTI	Informe de evaluación precontractual

1.3.2. 3.2 Fase de Incorporación

1. El proveedor designa un **contacto de seguridad** responsable ante la UNCP.
2. Se firma el **Acuerdo de Confidencialidad** específico.
3. La OTI crea las cuentas de acceso necesarias con **vigencia definida** y alcance restringido al servicio contratado.
4. Se configura el acceso remoto del proveedor mediante VPN institucional con MFA.
5. Se registra al proveedor en el inventario de terceros (registro auxiliar de la OTI).
6. El proveedor recibe y acusa recibo de las políticas de seguridad aplicables.

1.3.3. 3.3 Fase Operativa

3.3.1 Monitoreo Continuo

- La OTI revisa mensualmente los logs de acceso de las cuentas de proveedores.
- El SIEM debe generar alertas ante accesos fuera del horario autorizado o desde ubicaciones no habituales.
- Cualquier incidente de seguridad reportado por el proveedor debe seguir el procedimiento **P-SGSI-02 (Gestión de Incidentes)**.

3.3.2 Revisiones Periódicas

Tipo de Proveedor	Frecuencia	Actividades
Crítico	Anual	Auditoría in situ o remota de controles; verificación de certificaciones vigentes; revisión de SLAs
Alto	Cada 2 años	Revisión documental; solicitud de reportes de seguridad (SOC 2, ISO 27001); verificación de incidentes reportados
Medio	Al inicio y renovación	Confirmación de acuerdo de confidencialidad; verificación de vigencia de pólizas si aplica

1.3.4. 3.4 Fase de Cese y Terminación

3.4.1 Devolución de Activos Informáticos Al terminar el contrato, el proveedor debe: 1. Devolver íntegramente todos los datos de la UNCP en un formato interoperable acordado. 2. Certificar por escrito que ha eliminado todas las copias de datos UNCP de sus sistemas, respaldos y dispositivos. 3. Entregar los dispositivos físicos que hubiera recibido en préstamo, verificados según **F-SGSI-03 (Baja de Usuario y Devolución de Activos)**.

3.4.2 Desactivación de Accesos

- La OTI debe desactivar todas las cuentas de acceso del proveedor **en un plazo máximo de 24 horas** tras la fecha de término del contrato.
- Se debe revocar cualquier certificado digital, token o credencial de acceso emitida al proveedor.
- Se debe registrar la desactivación en el sistema de gestión de incidentes o de tickets.

3.4.3 Acta de Cierre Se levanta un acta de cierre firmada por el proveedor y la UNCP que certifique: - La devolución y eliminación de datos. - La desactivación de accesos. - La ausencia de reclamaciones de seguridad pendientes.

1.4. Requisitos de Seguridad por Tipo de Servicio

1.4.1. 4.1 Servicios Cloud (Huawei Cloud, Microsoft 365)

- El contrato debe especificar la **región geográfica** donde residirán los datos (debe cumplir la Ley N° 29733).
- La UNCP debe conservar la **propiedad y portabilidad** de sus datos.
- El proveedor debe permitir el **cifrado gestionado por la UNCP (CMK)** cuando aplique.
- Se debe definir un **plan de salida (exit plan)** con tiempos y costos.

1.4.2. 4.2 Servicios de Soporte y Mantenimiento

- El acceso remoto del personal de soporte debe ser **monitoreado y registrado**.
- Se prohíbe la transferencia de datos institucionales a dispositivos del proveedor sin autorización expresa.
- Las intervenciones deben realizarse dentro de ventanas de mantenimiento previamente acordadas.

1.4.3. 4.3 Servicios de Desarrollo de Software

- El código fuente desarrollado es propiedad de la UNCP.
- Se debe seguir la **POL-SGSI-01 (Desarrollo Seguro)**, incluyendo escaneo SAST/DAST.
- El código debe entregarse con el SBOM (Software Bill of Materials) actualizado.

1.5. Matriz de Proveedores Críticos (Registro)

La OTI mantendrá un **Registro Maestro de Proveedores** con los siguientes campos mínimos:

Campo	Descripción
ID Proveedor	Correlativo PROV-001
Razón Social	Nombre legal del proveedor
Servicio Contratado	Descripción del servicio
Nivel de Riesgo	Crítico / Alto / Medio / Bajo
Fecha de Inicio de Contrato	DD/MM/AAAA
Fecha de Fin de Contrato	DD/MM/AAAA
Contacto de Seguridad	Nombre, cargo, correo, teléfono
Certificaciones Vigentes	ISO 27001, SOC 2, etc.
Fecha de Última Evaluación	DD/MM/AAAA
Estado	Activo / En evaluación / En cese / Inactivo

1.6. Documentos Relacionados

Código	Nombre
POL-SGSI-04	Política de Seguridad con Proveedores
D-SGSI-04	Metodología de Evaluación y Tratamiento de Riesgos
P-SGSI-02	Marco de Respuesta a Incidentes (CSIRT)
P-SGSI-03	Gestión de Identidades y Control de Acceso
F-SGSI-01	Formato de Solicitud de Alta/Baja/Cambio de Acceso
F-SGSI-03	Formato de Baja de Usuario y Devolución de Activos

Elaborado por: Oficina de Tecnologías de la Información (OTI) — UNCP